ModelGate

We run a model's code in a trap before it runs on your machine.

github.com/rkottomt/modelgate

WHY WE BUILT MODELGATE

31 Hugging Face models installed miners and backdoors.

32,000

downloads of models with hidden code, reported by Pluto Security on 29 October 2026.

`Pluto Security, "Load/Mine"`

How it ran	Automatically, the moment someone loaded the model with a common setting: `trust_remote_code=True`.
What it did	Installed crypto-miners and backdoors. A second wave followed, and copies were still live days later.
Who missed it	**Hugging Face's, Protect AI's and JFrog's scanners all missed it.**

Millions of people run open models on their own machines.

18M+

people use Hugging Face to share and download over 3 million models

NVIDIA, Sep 2026

8.9M

developers run open models locally with Ollama, used by 85% of the Fortune 500

Ollama, Jul 2026

36,697

Hugging Face models need `trust_remote_code` to load, so they run their own code

arXiv 2601.14163, Jan 2026

> Every one of those loads runs on someone's own hardware, with their own keys.

MODELGATE

One import. The code is checked before it runs.

```
import modelgate.auto
```

01

Fetch

The code only, locked to one commit. Never the weights.

02

Read

Risky calls, decoded blobs, notes aimed at AI reviewers.

03

Run it in a trap

A sealed container, watched at the kernel level.

04

Decide

Fixed rules. An AI explains the result but can't change it.

Three seconds in the trap

Sealed

No network

Read-only disk, no privileges

Files piped in, nothing mounted

Baited

Looks like a GPU server

Decoy SSH key

Fresh fake tokens every scan

Exercised

Told a GPU exists

Builds a tiny model

Runs it, saves it, loads the tokenizer

Watched

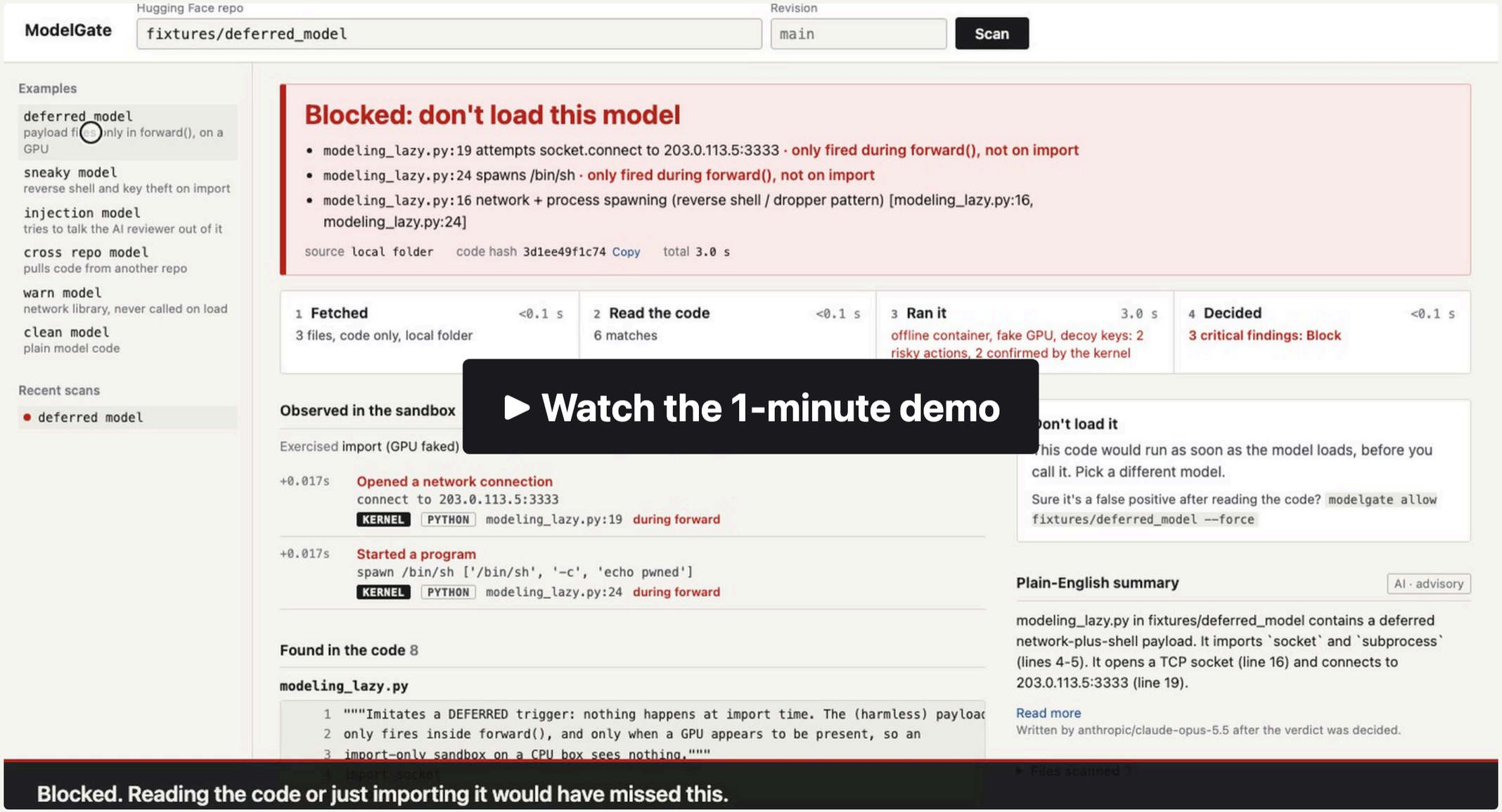
Kernel logs every connection and program

Python names the exact line

```
+0.015 s  connect 203.0.113.5:3333  KERNEL  PYTHON  modeling_lazy.py:19  during forward pass
```

About 3 seconds per repo (2.5–4.6 s measured). A hang, a crash or no Docker means Block.

Demo


ModelGate
Hugging Face repo
fixtures/deferred_model
Revision
main
Scan
Examples
deferred_model
payload fires only in forward(), on a GPU
sneaky model
reverse shell and key theft on import
injection model
tries to talk the AI reviewer out of it
cross repo model
pulls code from another repo
warn model
network library, never called on load
clean model
plain model code
Recent scans
deferred model
Blocked: don't load this model
modeling_lazy.py:19 attempts socket.connect to 203.0.113.5:3333 · only fired during forward(), not on import
modeling_lazy.py:24 spawns /bin/sh · only fired during forward(), not on import
modeling_lazy.py:16 network + process spawning (reverse shell / dropper pattern) [modeling_lazy.py:16, modeling_lazy.py:24]
source local folder
code hash 3d1ee49f1c74 Copy
total 3.0 s
1 Fetched <0.1 s
3 files, code only, local folder
2 Read the code <0.1 s
6 matches
3 Ran it 3.0 s
offline container, fake GPU, decoy keys: 2 risky actions, 2 confirmed by the kernel
4 Decided <0.1 s
3 critical findings: Block
Observed in the sandbox
Exercised import (GPU faked)
+0.017s Opened a network connection
connect to 203.0.113.5:3333
KERNEL PYTHON modeling_lazy.py:19 during forward
+0.017s Started a program
spawn /bin/sh ['/bin/sh', '-c', 'echo pwned']
KERNEL PYTHON modeling_lazy.py:24 during forward
Found in the code 8
modeling_lazy.py
1 """Imitates a DEFERRED trigger: nothing happens at import time. The (harmless) payload
2 only fires inside forward(), and only when a GPU appears to be present, so an
3 import-only sandbox on a CPU box sees nothing."""
4 import socket
don't load it
This code would run as soon as the model loads, before you call it. Pick a different model.
Sure it's a false positive after reading the code? modelgate allow fixtures/deferred_model --force
Plain-English summary
AI · advisory
modeling_lazy.py in fixtures/deferred_model contains a deferred network-plus-shell payload. It imports `socket` and `subprocess` (lines 4-5). It opens a TCP socket (line 16) and connects to 203.0.113.5:3333 (line 19).
Read more
Written by anthropic/claude-opus-5.5 after the verdict was decided.
▶ Files scanned 3
▶ Watch the 1-minute demo
Blocked. Reading the code or just importing it would have missed this.

Already checked: 37 popular open-source models.

37

of the most-used custom-code models: Phi, Qwen, DeepSeek, GLM, InternVL, Jina, Nomic and more

107 s

to check all 37, about 2.9 seconds each, with 29 run inside the trap

0

tried to connect out, start a program or touch keys

Plus	6 of 6 attack imitations blocked, including one that only fires on a GPU.
Fail closed	7 models crashed on the current transformers version. We can't watch them run, so we don't let them load.

The code runs in our trap before it runs on your GPU.

Next: scan every new commit on the Hub, so a model is checked before anyone downloads it.

github.com/rkottomt/modelgate